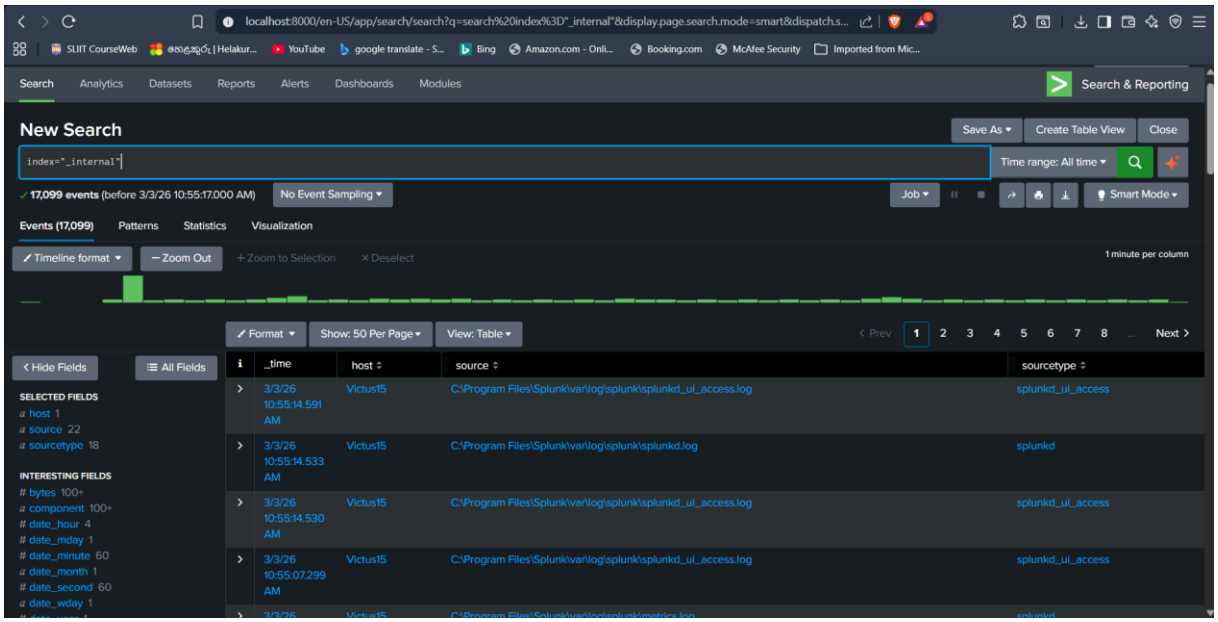
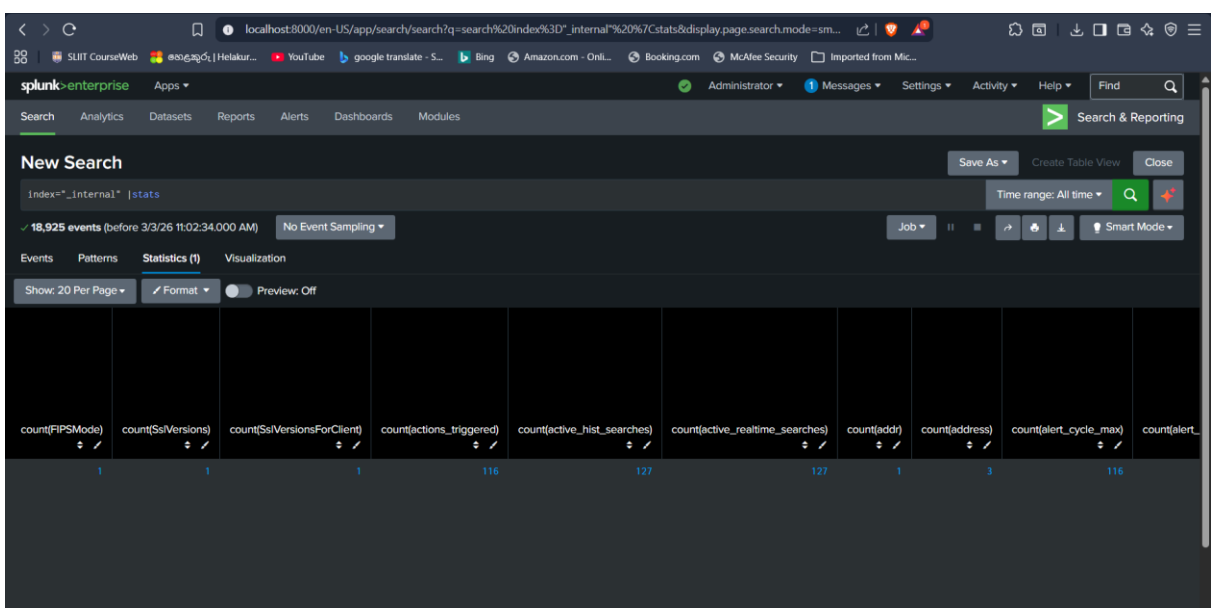
Splunk Enterprise

Every SOC investigation follows this flow:

- Identify index
- Filter by sourcetype
- Filter by user/IP/event
- Use stats to summarize
- Use timechart to detect anomalies

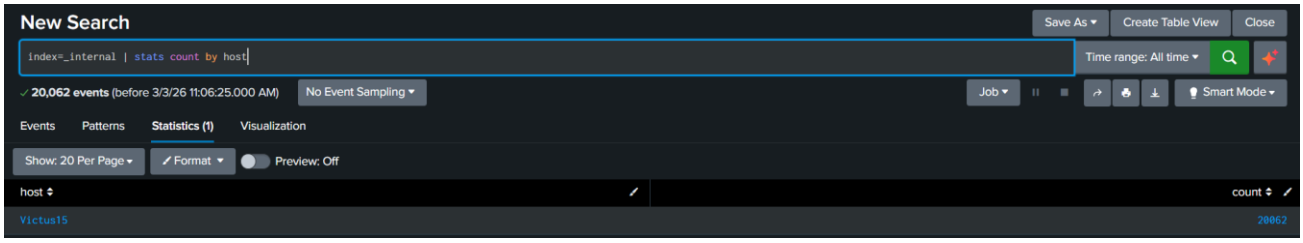
Index="_internal"





index=_internal | stats count

index=_internal | stats count by host



index=_internal | stats count by sourcetype

So you can detect:

- Failed logins
- Brute force attempts
- New user creation
- Admin privilege changes

Operationalizing information like time in and out, location, event type, and the like would facilitate future investigations into unusual behavior.

<u>Authorized access attempts</u>

We add a filter for only events where the access was granted (event_desc set to "Access Granted").

*index=main sourcetype=**TYPE** reader_desc=" **TYPE** " event_desc="Access Granted" employee_first_name="*"*
| timechart count by employee_first_name limit=10

<u>unauthorized access attempts</u>

event_desc of "Access Denied Unauthorized Entry Level" or "Access Denied Unauthorized Time".

*index=main sourcetype=**TYPE** event_desc="Access Denied Unauthorized Entry Level" OR event_desc="Access Denied Unauthorized Time" reader_desc="**TYPE**"*
| stats count by reader_desc, employee_first_name employee_job_title

Record your Investigation Details: During the physical security audit, we noted anomalies that should be investigated further by Frothly for individuals Mateo, Richard, and Nathaniel at Thirsty Berner Brewery.

Ex:

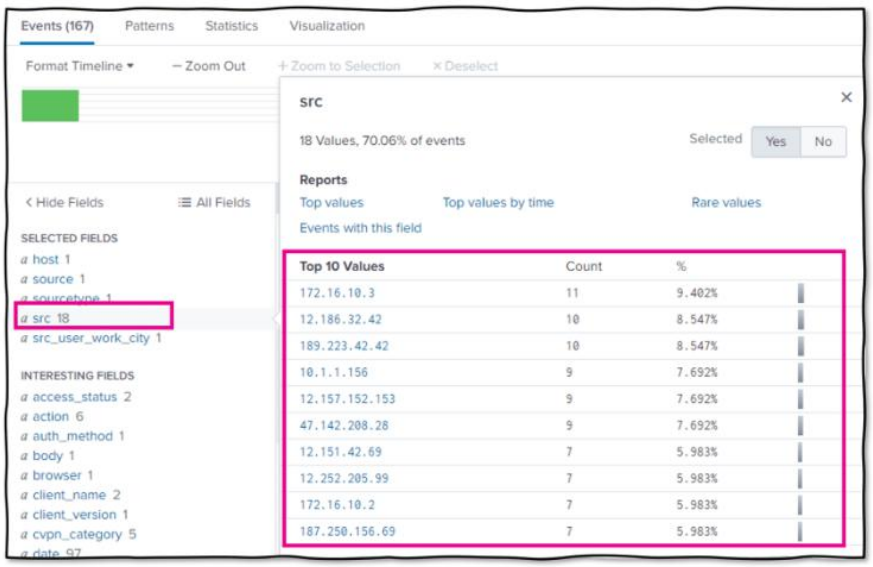
Frothly Beverages has asked us to review the login activity of one of their employees: Richard Schlitzer. Some activities in Salesforce raised questions while Richard was on-site with a customer in Tijuana, Mexico.

1. Examine data sources for VPN logins by Richard Schlitzer.
2. Use iplocation to see where Richard is logging in from.
3. Use geostats to visualize login data
4. Correlate data and analyze for anomalies

Analysis

Let's start by searching the last week of the Checkpoint firewall events for Richards's VPN logins.

index=main sourcetype="cp_log" user=Richards



use the function **iplocation,** to get a geographic location for the source IP addresses that the user is logging in from

index=main sourcetype="cp_log" user="richards"
| iplocation src
| where City!=""

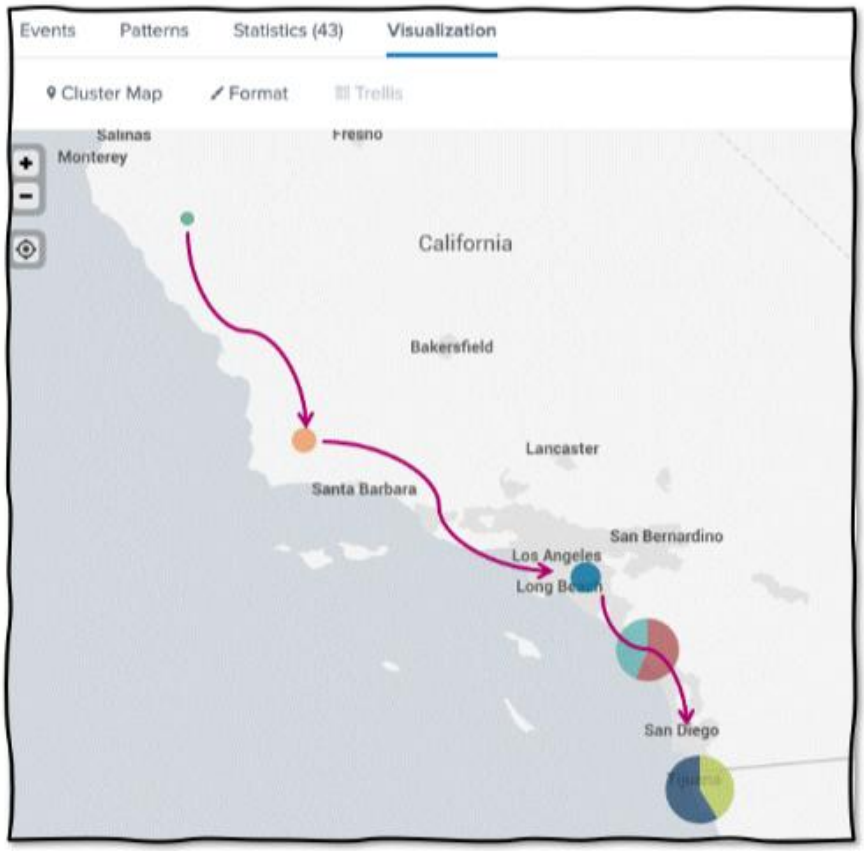
```Using the iplocation command with the src field where the city is **not** (!=) empty helps us remove events with an empty city.```
| *table* *src City Region Country lat long _time*
```The search then builds a table and deduplicates logins from the same IP address.```
| *dedup* *src*
| *sort* *_time*
```Finally, all that data is sorted by time. ```

src	City	Region	Country	lat	lon	_time
12.151.42.69	King City	California	United States	36.19740	-121.13220	2021-08-16 13:36:56
47.142.208.28	Los Alamos	California	United States	34.74720	-120.20290	2021-08-17 00:21:34
12.186.32.42	Anaheim	California	United States	33.84050	-117.95260	2021-08-18 01:54:43
12.252.205.99	San Juan Capistrano	California	United States	33.51040	-117.65910	2021-08-18 17:29:13
12.157.152.153	Oceanside	California	United States	33.24210	-117.30450	2021-08-18 21:09:36
189.223.42.42	Tijuana	Baja California	Mexico	32.44930	-117.02920	2021-08-19 15:02:29
187.250.156.69	Rosarito	Baja California	Mexico	32.36150	-117.04370	2021-08-20 06:57:30

So, according to our VPN logins, Richard's login activity started in northern California and moved down the coast into Mexico. This corresponds to his work activities for that week.

To show the location and the frequency logged in from each location for Richard. The **geostats** command will help with this

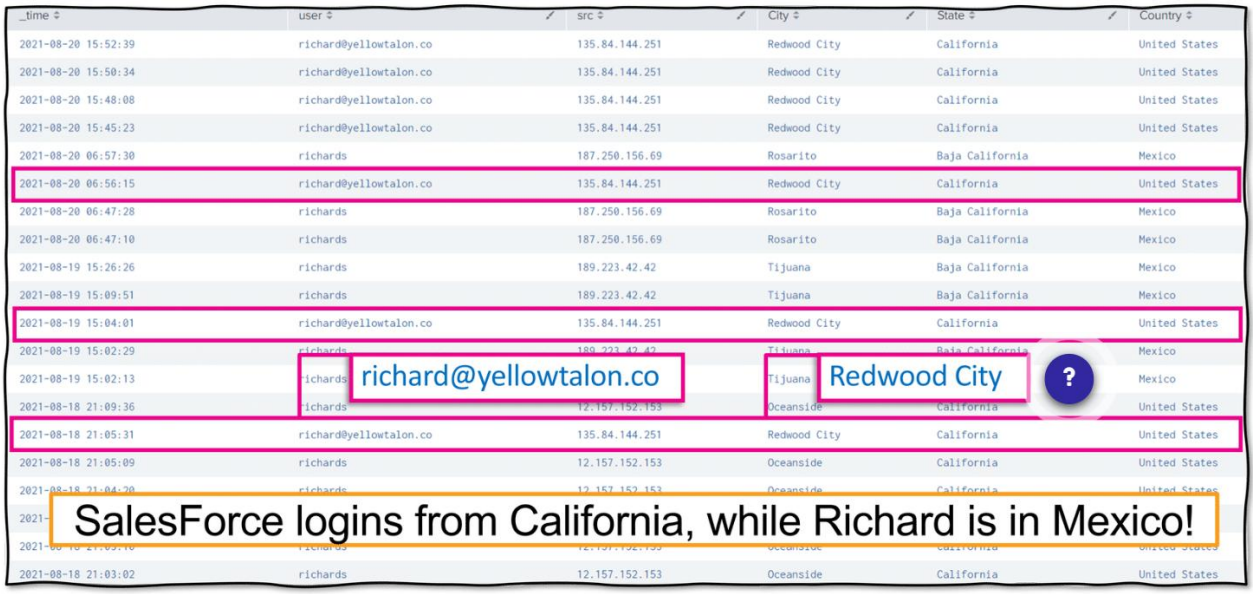
index=main (sourcetype="cp_log" OR source="sfdc_streaming_api_events:///login_events") (user=Richards OR Username="richard@yellowtalon.com")
| *iplocation src*
| *where City!=""*
| *geostats count by City latfield=lat longfield=lon*
```



Maybe we aren't looking at this the right way. Visualization is great, but the map didn't tell us anything.

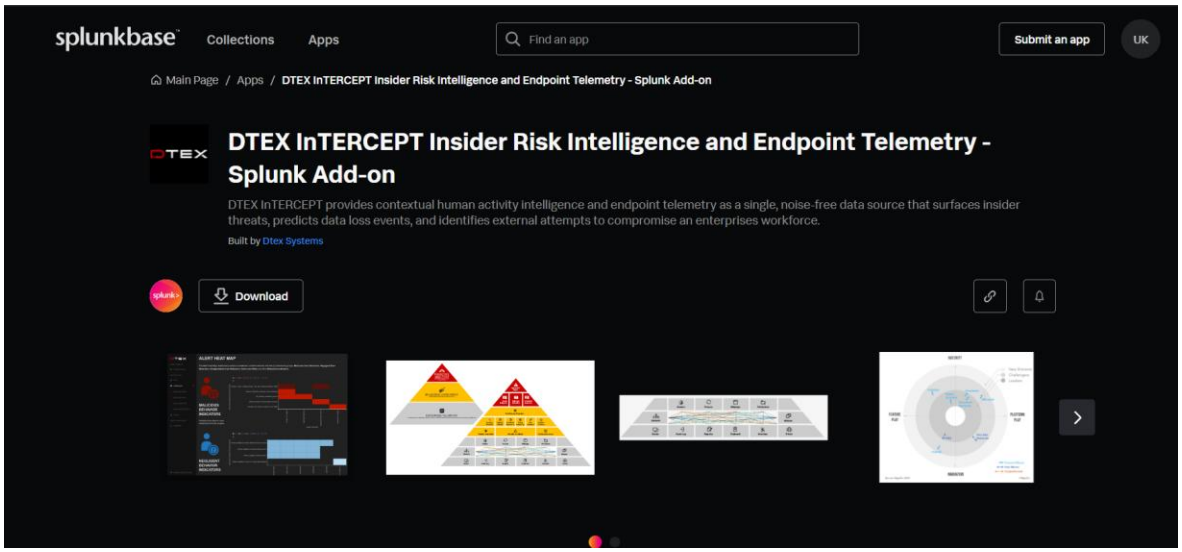
```
index=main (source="sfdc_streaming_api_events://login_events" OR sourcetype="cp_log")
(Username="richard@yellowtalon.co" OR user=richards)
| eval src=coalesce(src,SourceIp)
| eval user=coalesce(Username, user)
| iplocation src
| eval State=coalesce(Region, Subdivision)
| where City!=""
| table _time user src City State Country
| dedup _time
| sort -_time
```

Used OR and not AND, if we looked for events with the source of SalesForce AND a sourcetype of VPN we wouldn't get any results! They're different data sources.



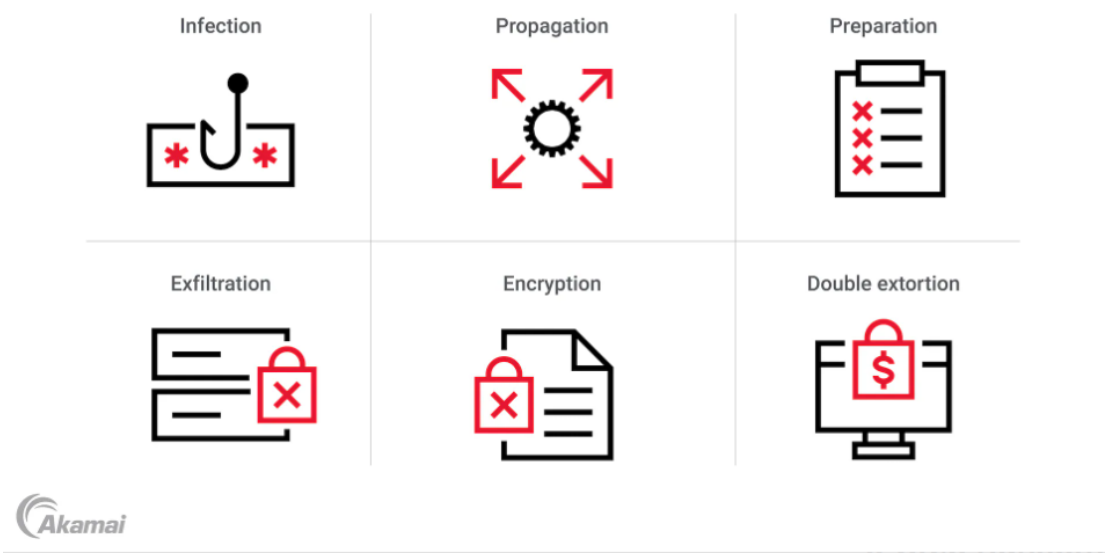
- Correlating VPN data with Salesforce data shows Richard's login has likely been compromised, or he is sharing it with someone else

The DTEX InTERCEPT agent that Frothly uses provides contextual human activity intelligence and endpoint telemetry for their on-premise assets. In the SOC, we use the DTEX Splunk Add-on from Splunkbase to collect events and alerts from the system.



index=dtex sourcetype=dtex_st_activities Activity_Group=FileSystemActivity Source_File_Extension=lockbit
| stats values(Activity_Details)

How LockBit ransomware attacks work



We need to find out what machines are reporting this therefore we need to search for the lockbit extension across all the DTEX data, and use stats and count to determine how many and which hosts may have been infected.

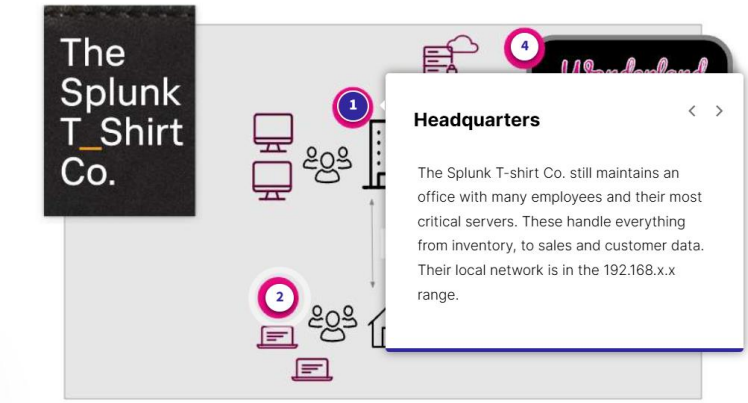
```
index=dtex sourcetype=dtex_st_activities Activity_Group=FileSystemActivity
Source_File_Extension=lockbit
| stats count by Device_Name
```

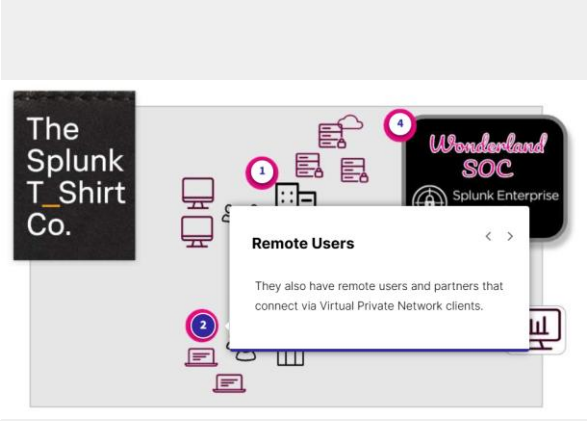
Udith Kaushalya

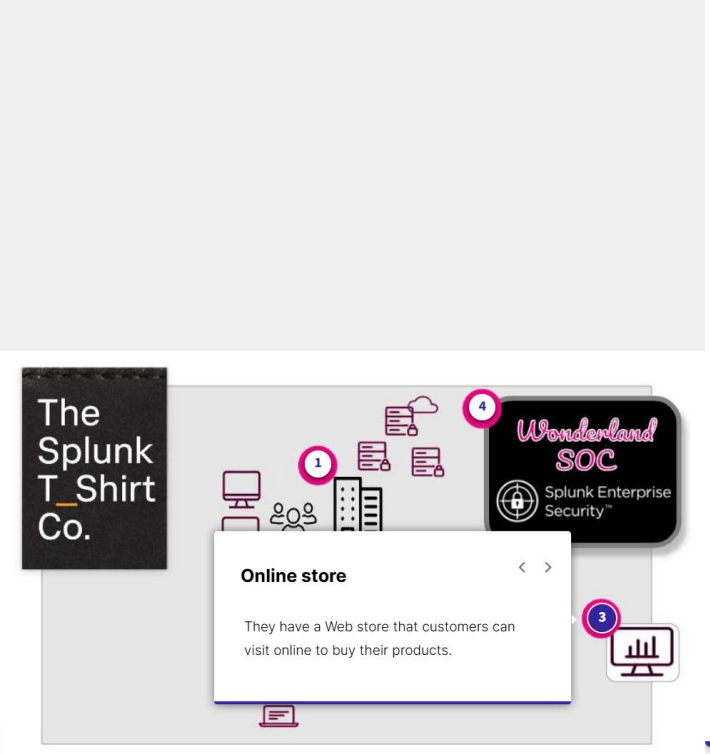
So as a summary we couldn't be able to find the inside threat we were looking for however we found a malware which stayed hidden from our system through our investigation.

Ex :

In this investigation we are working with the Splunk T-shirt company, here's a very high-level breakdown of their environment.







Security

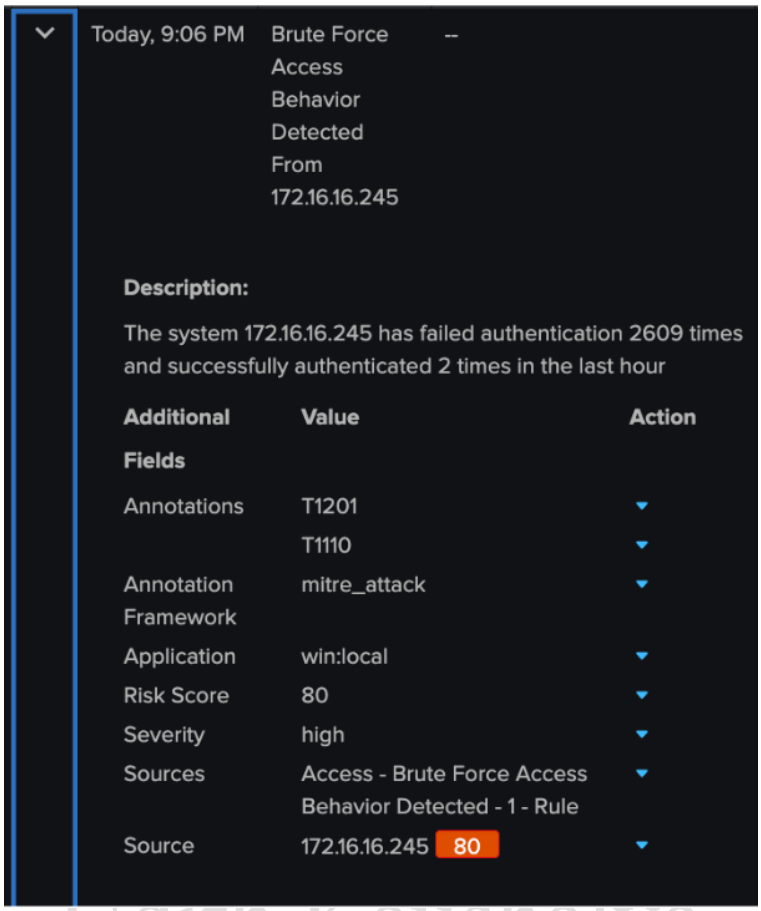
Firewalls, Web and Email proxies, and additional tools to protect their web store and provide redundancy to their local services.
Their most critical servers have EDR tools and all their user machines have an AntiVirus/Malware tool.

They of course send all important logs from their security devices to a Splunk Enterprise Security instance that the Wonderland SOC helps manage.

Their Splunk version is 9.0.4.1 with Enterprise Security 7.1.1.

an alert

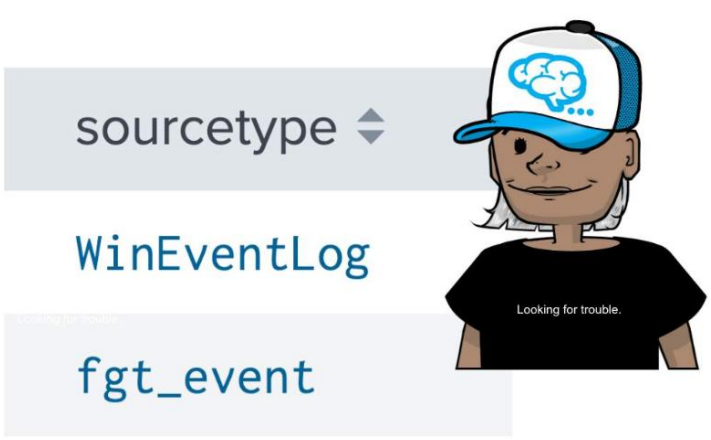
local network is in the 192.168.x.x but how we received a 172.x IP address in our logs.



Udith Kaushalya

Lets find the sourcetype by

index= 172.16.16.245 | stats count by sourcetype*



The result of our search shows two source types that call my attention:

- **WinEventLog :** This sourcetype is related to Windows events and usually contains authentication information so we might find there the logs that triggered our Brute Force search.

- **ftg_event:** This is a log from the customer's Fortigate firewall, it could give us a clue as to where this IP address is connecting from or what other activities it has attempted.

What is this ftg_event

index= 172.16.16.245 sourcetype=fgt_event*

Event

date=2024-03-25 time=09:07:17 devname=hogshead devid=FGT60D4614044725 logid=0101039947 type=event subtype=vpn level=information vd=root logdesc="SSL VPN tunnel up" action="tunnel-up" tunneltype="ssl-tunnel" tunnelid=379333608 remip=10.1.3.200 tunnelip=172.16.16.245 user="WeSellTshirts" group="MFAAUTH" dst_host="N/A" reason="N/A" msg="SSL tunnel established"

action = tunnel-up | source = 172.16.16.1 | sourcetype = fgt_event

date=2024-03-25 time=09:17:43 devname=hogshead devid=FGT60D4614044725 logid=0101039948 type=event subtype=vpn level=information vd=root logdesc="SSL VPN tunnel down" action="tunnel-down" tunneltype="ssl-tunnel" tunnelid=379333608 remip=10.1.3.200 tunnelip=172.16.16.245 user="WeSellTshirts" group="MFAAUTH" dst_host="N/A" reason="N/A" duration=626 sentbyte=2382051 rcvdbyte=2123827 msg="SSL tunnel shutdown"

action = tunnel-down | source = 172.16.16.1 | sourcetype = fgt_event

It's a vpn client

Event

date=2024-03-25 time=09:07:17 devname=hogshead devid=FGT60D4614044725 logid=0101039947 type=event subtype=vpn level=information vd=root logdesc="SSL VPN tunnel up" action="tunnel-up" tunneltype="ssl-tunnel" tunnelid=379333608 remip=10.1.3.200 tunnelip=172.16.16.245 user="WeSellTshirts" group="MFAAUTH" dst_host="N/A" reason="N/A" msg="SSL tunnel established"

action = tunnel-up | source = 172.16.16.1 | sourcetype = fgt_event | tunnelip = 172.16.16.245

date=2024-03-25 time=09:17:43 devname=hogshead devid=FGT60D4614044725 logid=0101039948 type=event subtype=vpn level=information vd=root logdesc="SSL VPN tunnel down" action="tunnel-down" tunneltype="ssl-tunnel" tunnelid=379333608 remip=10.1.3.200 tunnelip=172.16.16.245 user="WeSellTshirts" group="MFAAUTH" dst_host="N/A" reason="N/A" duration=626 sentbyte=2382051 rcvdbyte=2123827 msg="SSL tunnel shutdown"

action = tunnel-down | source = 172.16.16.1 | sourcetype = fgt_event | tunnelip = 172.16.16.245

Udit Kaushalya

However That doesn't necessarily explain all the failed authentication errors, so let's keep working on this.

Next source type

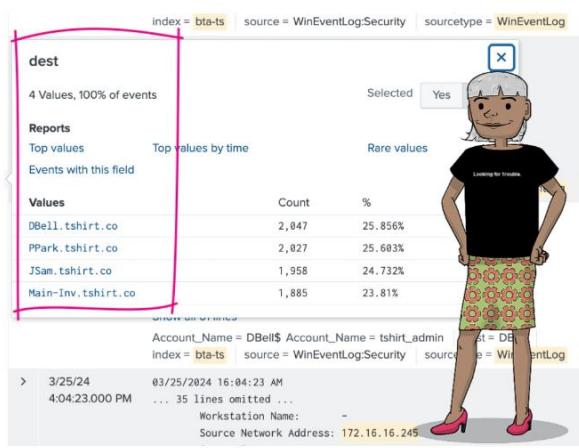
index= 172.16.16.245 sourcetype=WinEventLog*

look for interesting fields and take a quick look at them

So we found a few devices that were targeted by that 172.16.16.254 IP address:

- DBell
- PPark
- JSam
- Main-Inv

That's a very high number of events in a short period of time.



1. Suspicious activity triggered our "Brute Force Activity Detected" rule which is tied to Credential Access and Discovery MITRE ATT&CK™ tactics.

2. The source IP of this activity (172.16.16.245) is from a user connecting through a VPN that is reserved for a partner that helps with the company's international sales.
3. This IP has hundreds of failed authentication attempts against at least 4 different devices, one of which seems like a corporate server (Main-Inv).
4. There were at least 2 "successfully logged in" messages in the records.

Enterprise tactics

Tactics represent the "why" of an ATT&CK technique or sub-technique. It is the adversary's tactical goal: the reason for performing an action. For example, an adversary may want to achieve credential access.

ID	Name	Description
TA0043	Reconnaissance	The adversary is trying to gather information they can use to plan future operations.
TA0042	Resource Development	The adversary is trying to establish resources they can use to support operations.
TA0001	Initial Access	The adversary is trying to get into your network.
TA0002	Execution	The adversary is trying to run malicious code.
TA0003	Persistence	The adversary is trying to maintain their foothold.
TA0004	Privilege Escalation	The adversary is trying to gain higher-level permissions.
TA0005	Defense Evasion	The adversary is trying to avoid being detected.
TA0006	Credential Access	The adversary is trying to steal account names and passwords.
TA0007	Discovery	The adversary is trying to figure out your environment.
TA0008	Lateral Movement	The adversary is trying to move through your environment.
TA0009	Collection	The adversary is trying to gather data of interest to their goal.
TA0011	Command and Control	The adversary is trying to communicate with compromised systems to control them.
TA0010	Exfiltration	The adversary is trying to steal data.
TA0040	Impact	The adversary is trying to manipulate, interrupt, or destroy your systems and data.

Udith Kaushalya

What if we found a suspicious IP

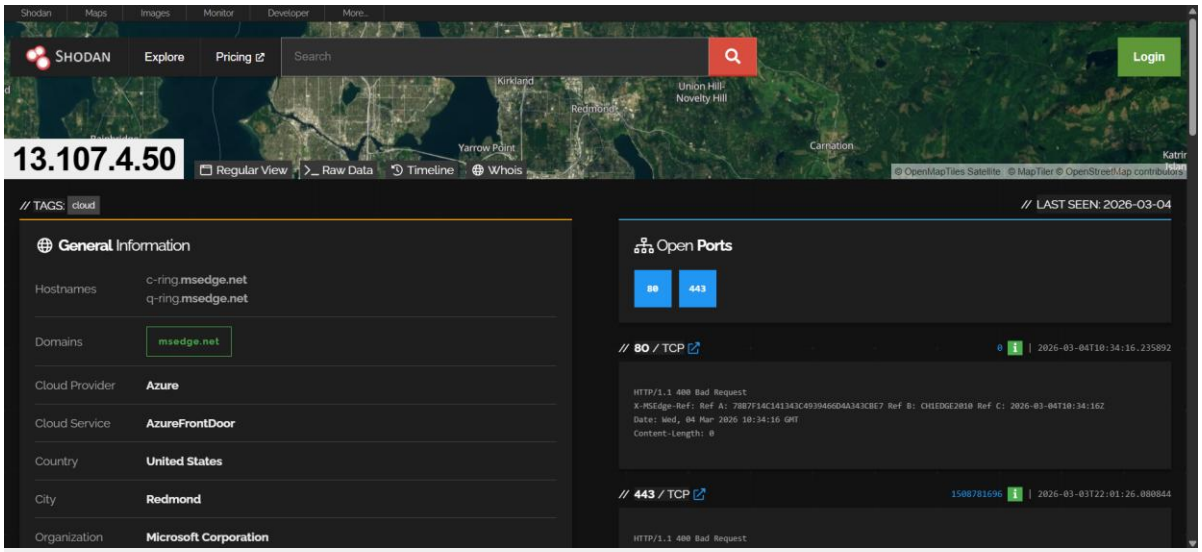
Investigate Threat Indicators (IOC)

Tools which stores **Indicators of Compromise (IOC)** such as:

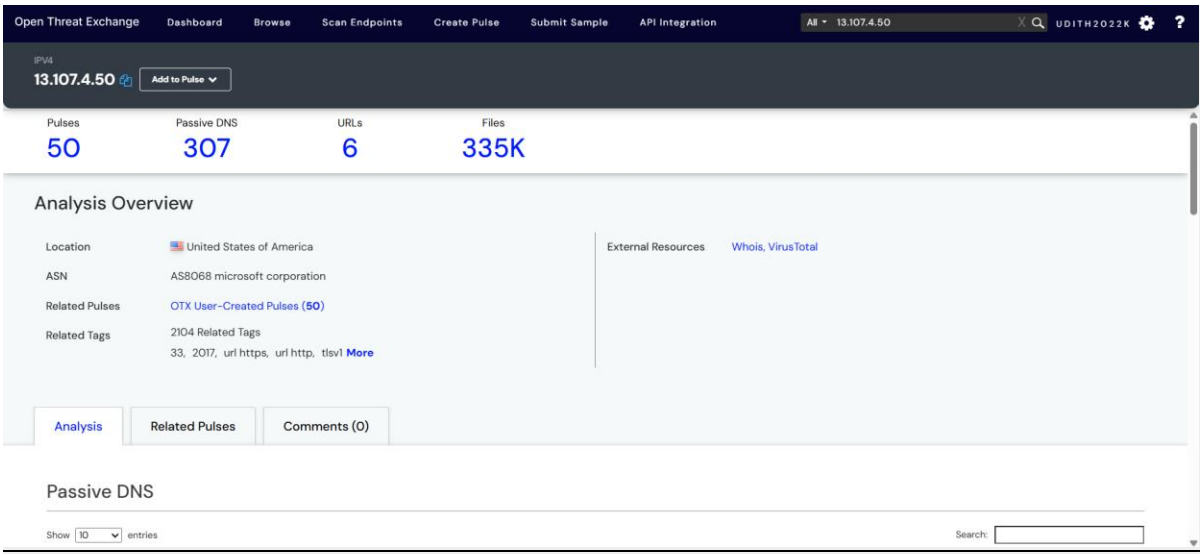
- IP addresses
- Domains
- URLs
- File hashes
- Malware samples

Threat intelligence platforms that allows security professionals to share indicators of compromise such as malicious IPs, domains, and malware hashes. SOC analysts use it to investigate suspicious activity and identify known threats. Given below are some of the free analysis tools.

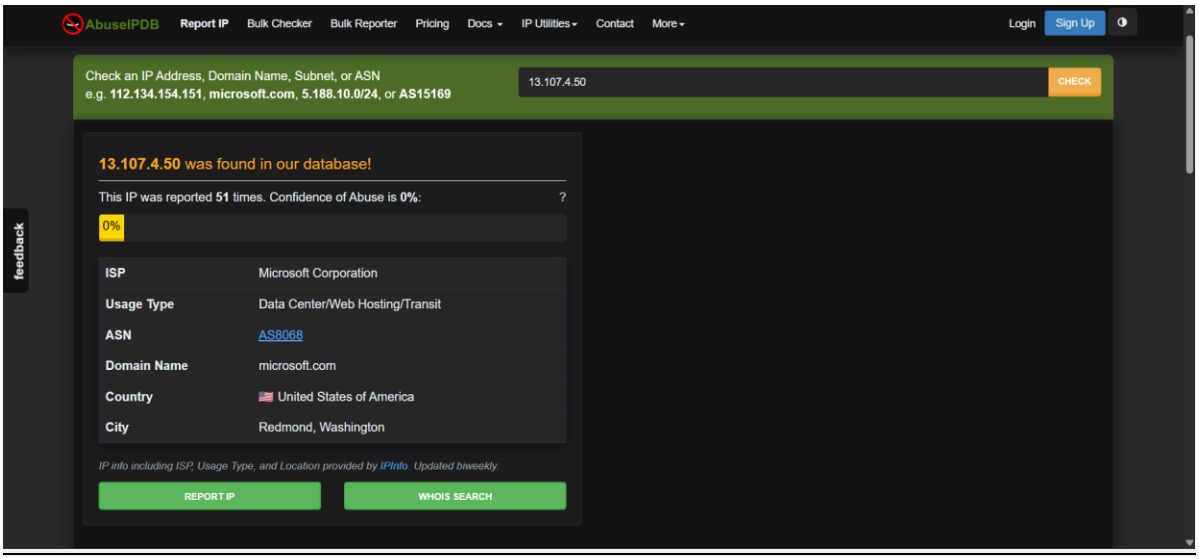
Shodan



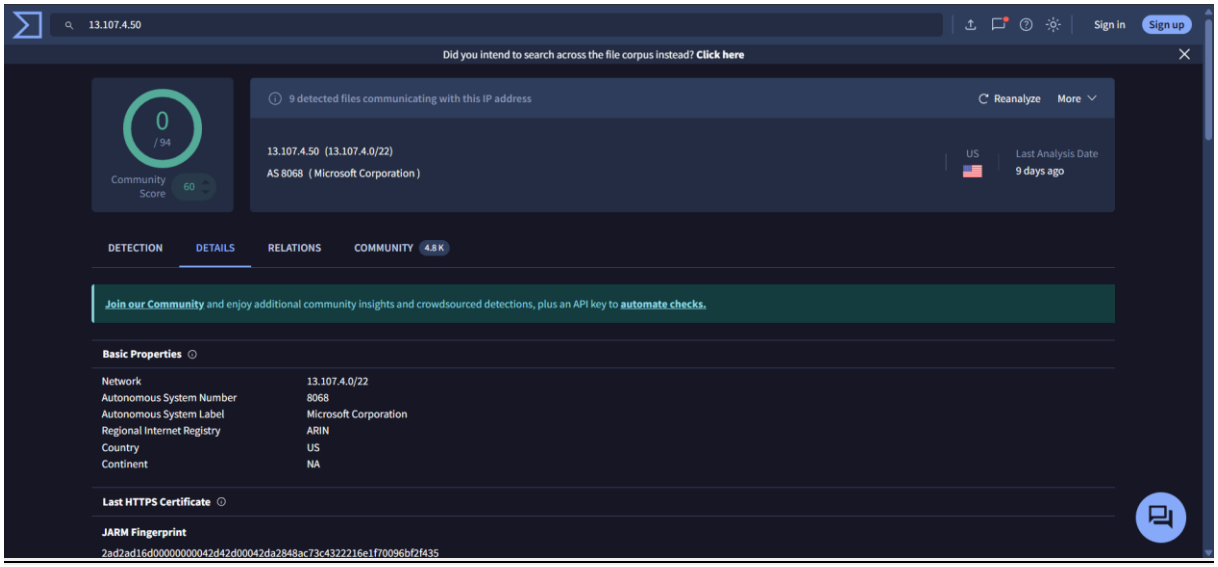
AlienVault OTX



AbuseIPDB



VirusTotal



Udith Kaushalya